Cryptoperiod Catastrophe

Misapplication of bare signatures/anon-signatures to non-ephemeral verifiable credential

https://kericonf.com

Samuel M. Smith PhD
sam@kerisuite.org
https://keri.foundation

Cryptoperiod

Essential crypto key property in NIST SP 800-57 Part 1 Rev. 5

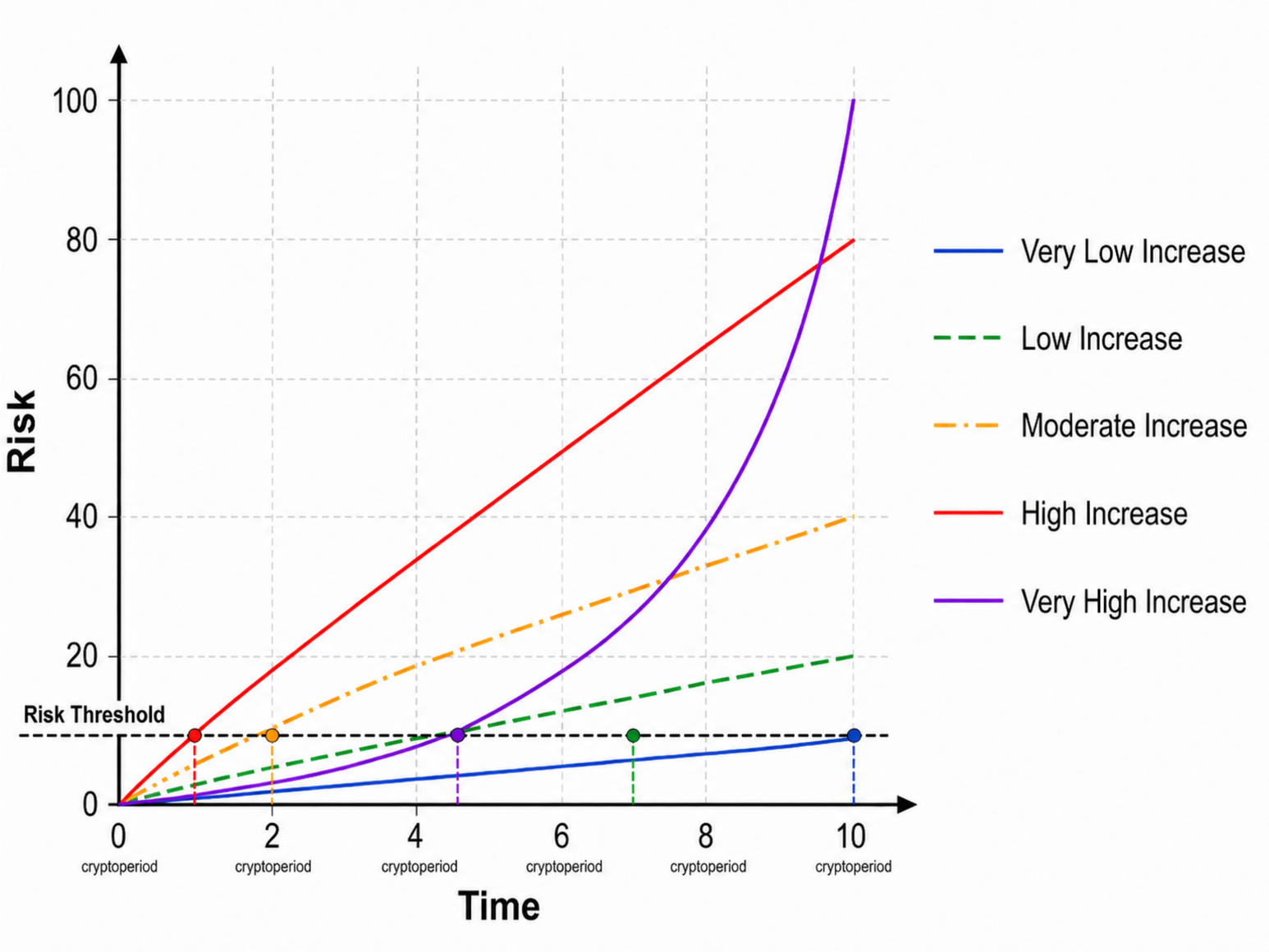
Recommendation for Key Management: Part 1 – General (https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-57pt1r5.pdf)

The term *cryptoperiod* is used 239 times in SP 800-57 p1

cryptoperiod: the time span during which a specific key is authorized for use or in which the keys for a given system or application may remain in effect.

Cryptoperiods reflect the actuarial exposure risk over time

Cryptoperiod = Risk Threshold



Cryptoperiod in Detail

A cryptoperiod is the time span during which a specific key is authorized for use by legitimate entities or the keys for a given system will remain in effect.

A suitably defined cryptoperiod:

1. Limits the amount of information that is available for cryptanalysis to reveal the key;
2. Limits the amount of exposure if a single key is compromised;
3. Limits the use of a particular algorithm (e.g., to its estimated effective lifetime); *(all non-PQ safe keys now have an effective maximum cryptoperiod of 4 years circa 2030)*
4. Limits the time available for attempts to penetrate physical, procedural, and logical access mechanisms that protect a key from unauthorized disclosure;
5 Limits the period within which information may be compromised by inadvertent disclosure of a cryptographic key to unauthorized entities; and
6. Limits the time available for computationally intensive cryptanalysis.

Cryptoperiod Determination

5.3 Sometimes, cryptoperiods are defined by an arbitrary time period or maximum amount of data protected by the key.

However, trade-offs associated with the determination of cryptoperiods involve the risk and consequences of exposure, which should be carefully considered when selecting the cryptoperiod.

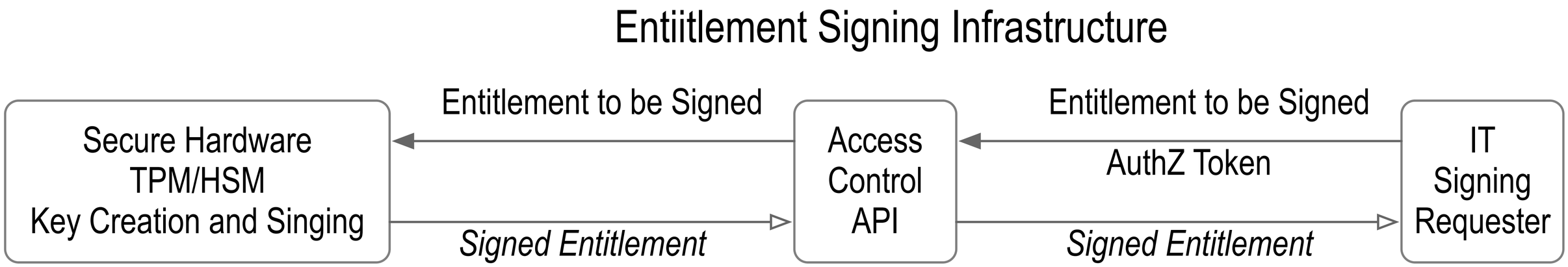
If a key is compromised, its cryptoperiod shall no longer be considered valid.

All cryptoperiods are dynamically aborted by compromise

Factors Affecting Cryptoperiods 5.3.1

1. The strength of the cryptographic mechanisms (e.g., the algorithm, key length, block size, and mode of operation);
2. The embodiment of the mechanisms;
3. The operating environment;
4. Personnel turnover (e.g., of system administrators and CA system personnel);
5. The volume of data flow or the number of transactions;
6. The security life of the data;
7. Limitations required for algorithm usage (e.g., nonce reuse);
8. The security function (encryption, digital signature, key derivation, or key protection);
9. The re-keying method;
10. The re-keying or key-derivation process used;
11. The number of nodes in a network that share a common key;
12. The number of copies of a key and the distribution of those copies;
13. The threat to the information from adversaries (technical capabilities and resources to mount an attack);
14. The threat to the information from new and disruptive technologies (e.g., quantum computers).

Conventional Enterprise Signing Infrastructure



Best practice is to use secure signing hardware (TPM, HSM, Secure Enclave).

Private key never leaves hardware. Public key broadcast to verify signature.

Role-based access control grants AuthZ permissions/tokens to employees who submit entitlements to secure hardware for signing.

The weakest vulnerability is the AuthZ infrastructure, not the signing hardware. (typically OAuth/OIDC/SSO based)

Systems that do not use secure signing hardware are also vulnerable to direct private key compromise

Attack on Signing Authorization

Compromise of the signing authorization infrastructure results in fraudulent but perfectly verifiable entitlements

Typically, AuthZ permissions are repudiable (bearer tokens), thereby creating plausible deniability

Plausible deniability = incentive to suborn = insider attacks

Consequences of Exposure

The consequences of exposure are measured by the sensitivity of the information, the criticality of the processes protected by the cryptography, and the cost of recovery from the compromise of the information or processes.

Sensitivity refers to the lifespan of the information being protected and the potential consequences of a loss of protection for that information.

In general, as the sensitivity of the information or the criticality of the processes protected by cryptography increase, the length of the associated cryptoperiods should decrease in order to limit the damage that might result from each compromise.

This is subject to the caveat regarding the security and integrity of the re-keying or key-derivation process.

However, short cryptoperiods may be counter-productive, particularly where denial-of-service is the paramount concern and there is a significant potential for error in the re-keying or key-derivation process.

Private/Public Authentication Keys

A private authentication key may be used multiple times to enable data integrity and identity authentication.

An appropriate cryptoperiod for a private authentication key would be **no more than one or two years**, depending on its usage environment and the sensitivity/criticality of the authenticated information.

In most cases, the cryptoperiod of a public authentication key is the same as the cryptoperiod of the corresponding private authentication key. The cryptoperiod is, in effect, the period during which the identity of the originator of information protected by the corresponding private authentication key needs to be verified (i.e., the identity needs to be authenticated).

An appropriate cryptoperiod for a public authentication key would be **no more than one or two years**, depending on its usage environment and the sensitivity/criticality of the authenticated information.

Private/Public Authorization Keys

A private authorization key may be used for an extended period of time, depending on the resources that are protected and the role of the entity authorized for access.

The primary considerations in establishing the cryptoperiod for a private authorization key includes the robustness of the key, the adequacy of the cryptographic method, and the adequacy of the key-protection mechanisms and procedures.

The cryptoperiod of a private authorization key and its corresponding public key shall be the same.

Given the use of an approved algorithm and key size and an expectation that the security of the key-storage and use environment will increase as the sensitivity and criticality of the authorization processes increases, it is recommended that a cryptoperiod for a private authorization key be **no more than two years**.

A public authorization key is the public element of an asymmetric key pair that is used to verify privileges for an entity that possesses the corresponding private key.

The cryptoperiod of a public authorization key shall be the same as that of the private authorization key – **no more than two years**.

In the real world cryptoperiods are *dynamic*

Staff changes

Technology changes

Attack incentive structure changes

Sensitivity/Criticality changes

Susceptibility/Vulnerability/Recoverability changes

Suspected compromise

Actual compromise

Bare Signatures for AuthN/AuthZ

Bare means proof is an attached signature; no other mechanism is used to ensure the signature was created during the cryptoperiod of the private key.

This applies to all asymmetric digital signature algorithms: basic (Ed25515, ECDSA) and anonymous (BBS+, Anoncreds, etc)

It is an egregious violation of best practices for key management to use bare signatures as proof of AuthN/Authz for issuances whose verifiable life span exceeds the cryptoperiod of the issuing key pair.

Misapplications of Bare Signatures for Issuances

birth certificates (lifelong)

proof-of-citizenship (lifelong)

proof-of-age (lifelong)

guardianship (18 years - lifelong)

voter-registration (lifelong)

disabled entitlements (lifelong)

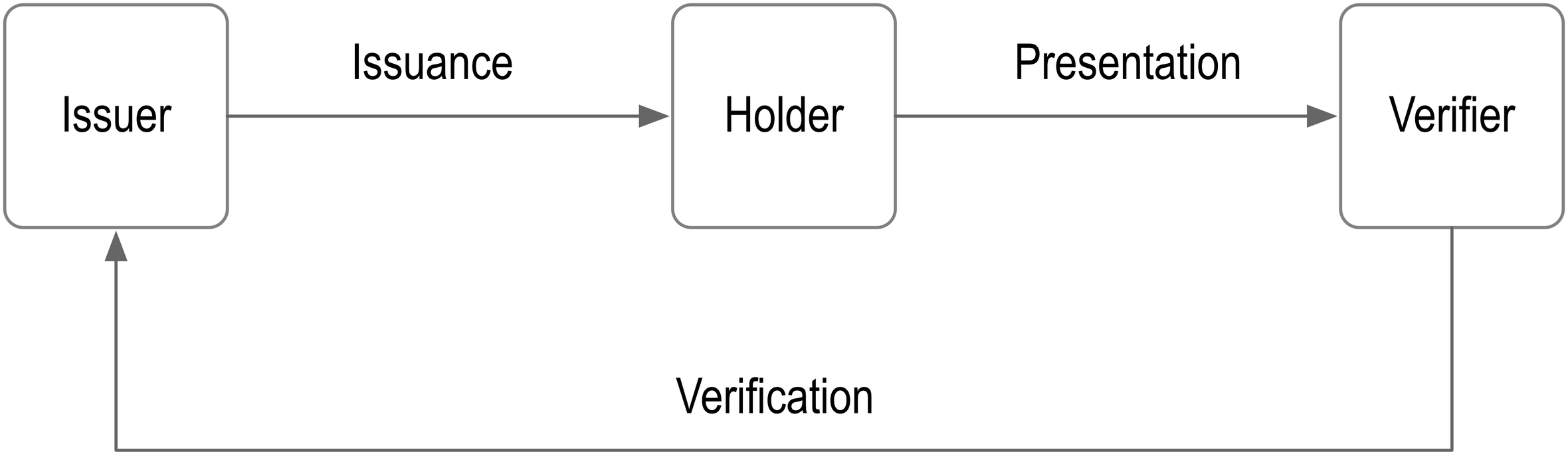
driver's licenses (5 years)

passports (10 years)

all unrevocable licensing that exceeds the exploitation risk profile of issuer's signing infrastructure

Closed Loop Models for Entitlement Verification

Issuer-Holder-Verifier Model with Verification at Issuer

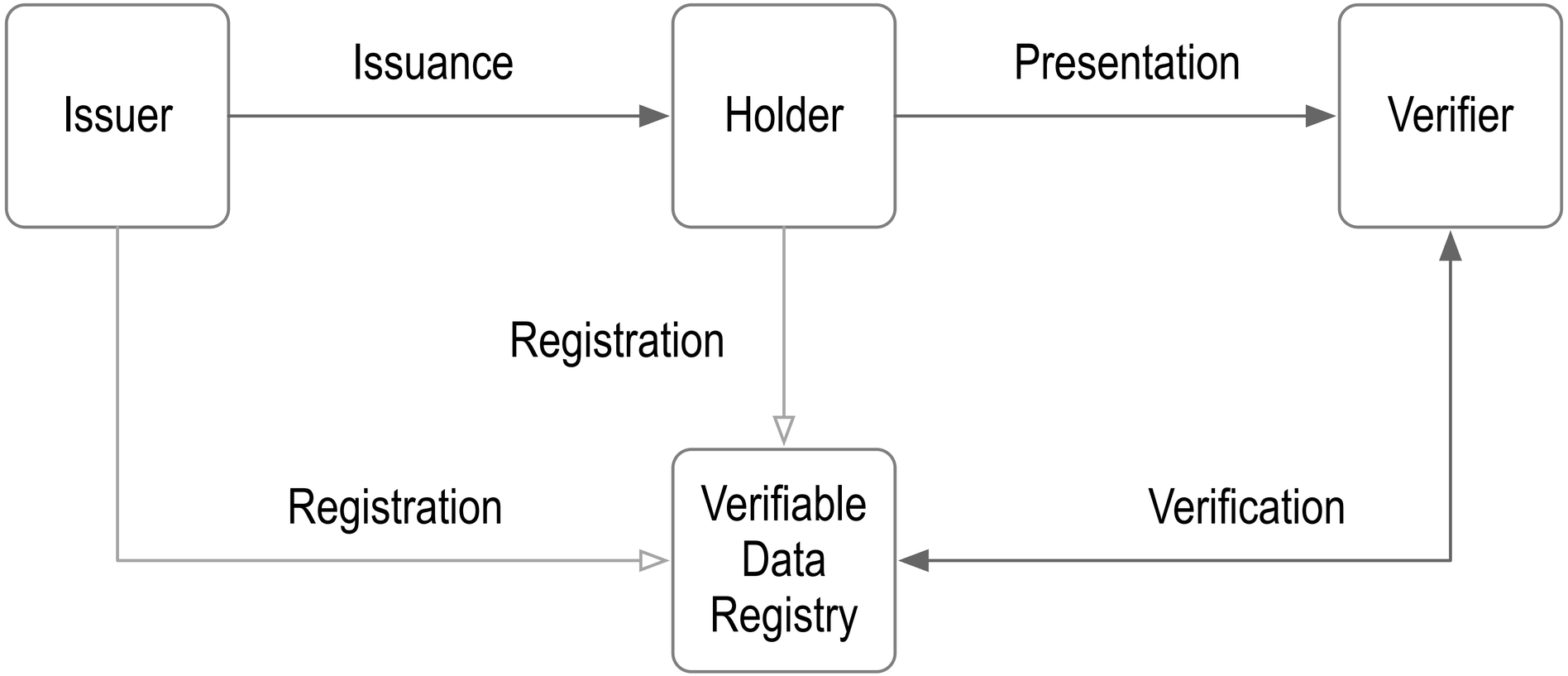


Phone-home defeats anti-tracking/correlation protections

Closed loop (phone-home) allows very short cryptoperiods for AuthN/AuthZ key pairs

Open Loop Models for Entitlement Verification

Issuer-Holder-Verifier Model with Verification using Verifiable Data Registry



VDR enables anti-tracking/correlation protections

VDR requires reissuance whenever issuer AuthN/AuthZ keys are rotated

This makes VDR impractical for short AuthN/AuthZ cryptoperiods

Survivable Security

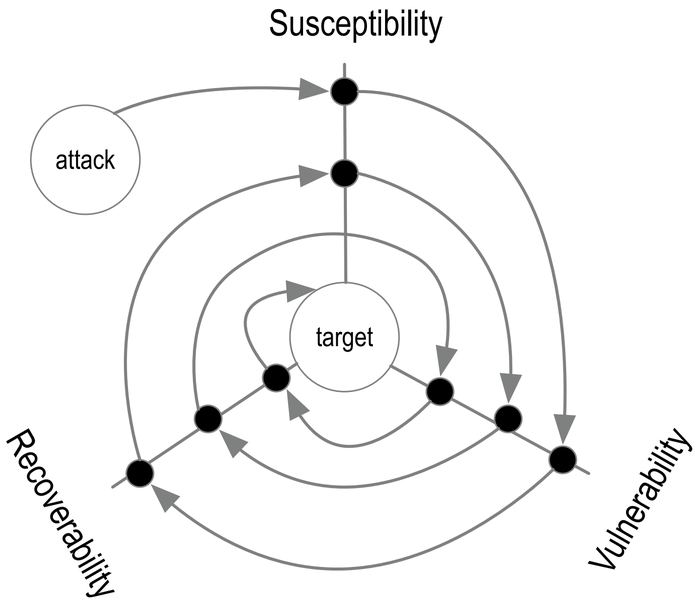
Survivability:

- Susceptibility – Likelihood of being attacked
- Vulnerability – Likelihood of success and extent of harm given an attack
- Recoverability – Likelihood and extent of recovery from a successful attack

A system may be highly vulnerable but not highly susceptible to attack

In IT security, susceptibility stems from the return on investment (ROI) of an attack

The "trap" of confusing low susceptibility with low vulnerability



Layered Survivabilty Overlay Spiral

Critical Properties of Government Issued Entitlements

Persistence: potentially life-long timespans over which entitlement needs to verifiable

Millions of issuances: Makes mass revocation and re-issuance problematic

High value entitlements: Economic assistance, health care, etc.

Potential to become the citizen identity assurance root-of-trust for intra-state, inter-state, federal, and private ecosystems

Potential to replace existing decentralized identity assurance mechanisms with single universal State endorsement.

Persistent, widespread, high value, entitlement system:

Highest ROI to attackers = Highest susceptibility to attack.

Highest susceptibility means all vulnerabilities will be exploited eventually.

Systemic Design Flaw = Unbounded Risk

Issuer signing infrastructure:

Single point of failure for the whole ecosystem of State-issued credentials/entitlements

Its compromise would result in rampant impersonation fraud.

= catastrophic failure potential = annihilation of trust

The exponential increase in adoption due to state support amplifies the likelihood (risk) of such a catastrophic failure

Security over issuer signing Infrastructure must therefore employ exponentially stronger security measures

Tradespace Threats

Identity Theft

Attention Theft

Intimidation

Tradespace Mitigations

Perpetual Identity

Pepetually Verifiable Issuances

Control over Context

Disclosure, Presence, & Usage

Identity Based Attack Statistics 2024

Crowdstrike 2025 report: https://go.crowdstrike.com/rs/281-OBQ-266/images/CrowdStrikeGlobalThreatReport2025.pdf?version=0

Breakout time — average fell to 48 minutes

Voice phishing — up 442% between the first and second half of 2024.

Initial access attacks — 52% of vulnerabilities in 2024. Access broker offerings increased 50% year-over-year.

China-nexus activity surged 150%; targeted industries 200% to 300%

GenAI enabled infiltration via deep fake IT job candidate and recruiter exploits

GenAI Exploit Chaining

Time to Detect and Contain 2024

IBM 2025 data breach report: https://www.ibm.com/reports/data-breach

Average Detection and Containment:

In 2024, the total average lifecycle from initial breach to containment was 194 days to identify and 64 days to contain (258 days).
Stolen Credentials: Breaches that begin with stolen or compromised credentials take the longest, with an average lifecycle of 292 days.

Edge Attack on Authorization System

OAuth/OIDC, PKI/CA, DNS Hijack, VPN, Remote CLI apps

Phishing employee login credentials

- AI enabled phishing (10x over 2024, 100x over 2023)

https://www.theepochtimes.com/tech/microsoft-sharp-increase-in-ai-aided-cyberattacks-from-russia-china-5931764

Recursive privilege escalation attack

- Stolen bearer tokens (Salesloft Drift->Salesforce->AWS->Google->ZScaler->PaloAlto)

Key compromise impersonation attack

Zero Day (share point etc)

Insider Exploit

suborn: *incite secretly, bribe or otherwise induce (someone) to commit an unlawful act.*

https://www.theepochtimes.com/tech/microsoft-sharp-increase-in-ai-aided-cyberattacks-from-russia-china-5931764

https://www.theepochtimes.com/tech/microsoft-sharp-increase-in-ai-aided-cyberattacks-from-russia-china-5931764

Disgruntled employee: bribe, revenge,

Compromised employee: black mail, familial threats

Fake Employee Infiltration: GenAI remote live fakes

KERI

KERI CONF 2026

KERI FOUNDATION

Usage Periods

For asymmetric-key key pairs, each key of the pair has its own cryptoperiod.

One key of the key pair is used to apply cryptographic protection (e.g., create a digital signature), and its cryptoperiod is called the “originator-usage period.”

The other key of the key pair is used to process the protected information (e.g., verify a digital signature); its cryptoperiod is called the “recipient-usage period.”

The key pair’s originator and recipient-usage periods typically begin at the same time, but the recipient-usage period may extend beyond the originator-usage period.

Private Signature Key

Given the use of an approved algorithm and key size as well as an expectation that the security of the key-storage and use environment will increase as the sensitivity and/or criticality of the processes for which the key provides integrity protection increases, a maximum cryptoperiod of about one to three years is recommended.

A private signature key shall be destroyed at the end of its cryptoperiod.

Public Signature Verification Key

In general, the cryptoperiod of a public signature-verification key may be longer than the cryptoperiod of the corresponding private signature key.

The cryptoperiod may be on the order of several years. However, due to the long exposure of protection mechanisms to hostile attack, the reliability of the signature is reduced with the passage of time.

Some systems use a cryptographic timestamping function to place an unforgeable timestamp on each signed message.

Even when the cryptoperiod of a private signature key has expired, the corresponding public signature-verification key may be used to verify signatures on messages whose timestamps are within the cryptoperiod of the private signature key.

I*n this case, one is relying on the cryptographic timestamp function to provide assurance that the message was signed within the private signature key's originator-usage period.*